OpenShift Security Architecture

The Blueprint for Enterprise Trust

Red Hat

The Complexity of Kubernetes Security

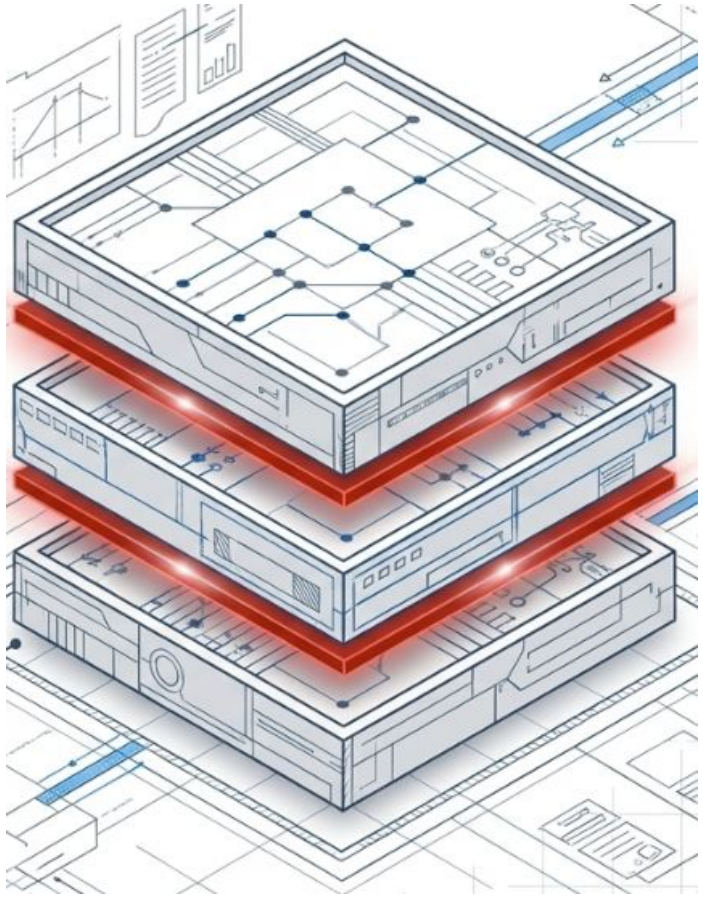
According to NSA and CISA hardening guidelines, securing a vanilla Kubernetes cluster requires mitigating multiple threat vectors manually:

- Network separation and firewall enforcement.
- Strong authentication and RBAC implementation.
- Audit logging and threat detection.
- Rejecting root-executing containers.

Red Hat

Agenda

- Security layers in OpenShift
- Identity, access, and secrets
- Platform hardening and compliance
- Network and workload isolation
- Supply chain and updates
- Security certifications and attestations
- Summary



Security Layers

Update **confidential** designator here

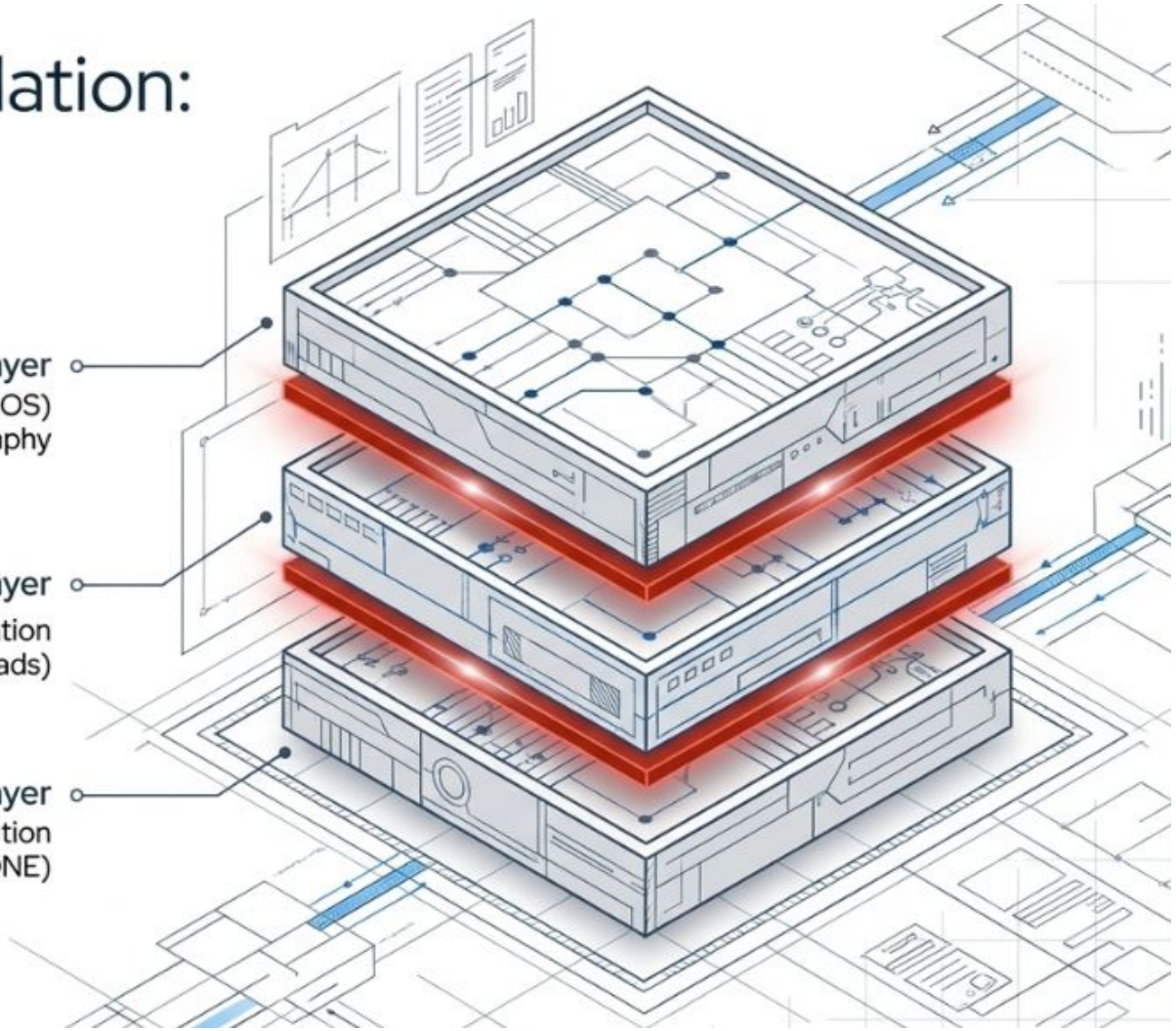
Defense in Depth

Kubernetes-native + OpenShift extensions

- Hardened host OS (RHEL CoreOS or RHEL nodes)
- Control plane protection, TLS, API authentication
- Namespace isolation, RBAC, admission control
- Container runtime constraints and Security Context Constraints (SCCs)
- Optional: FIPS-validated cryptography where required

Red Hat

The Certified Foundation: Hardware to OS



Operating System Layer
Red Hat Enterprise Linux CoreOS (RHCOS)
& FIPS 140-2/140-3 validated cryptography

Hypervisor / Platform Layer
Microsoft SVVP (Certified virtualization
for Windows Server workloads)

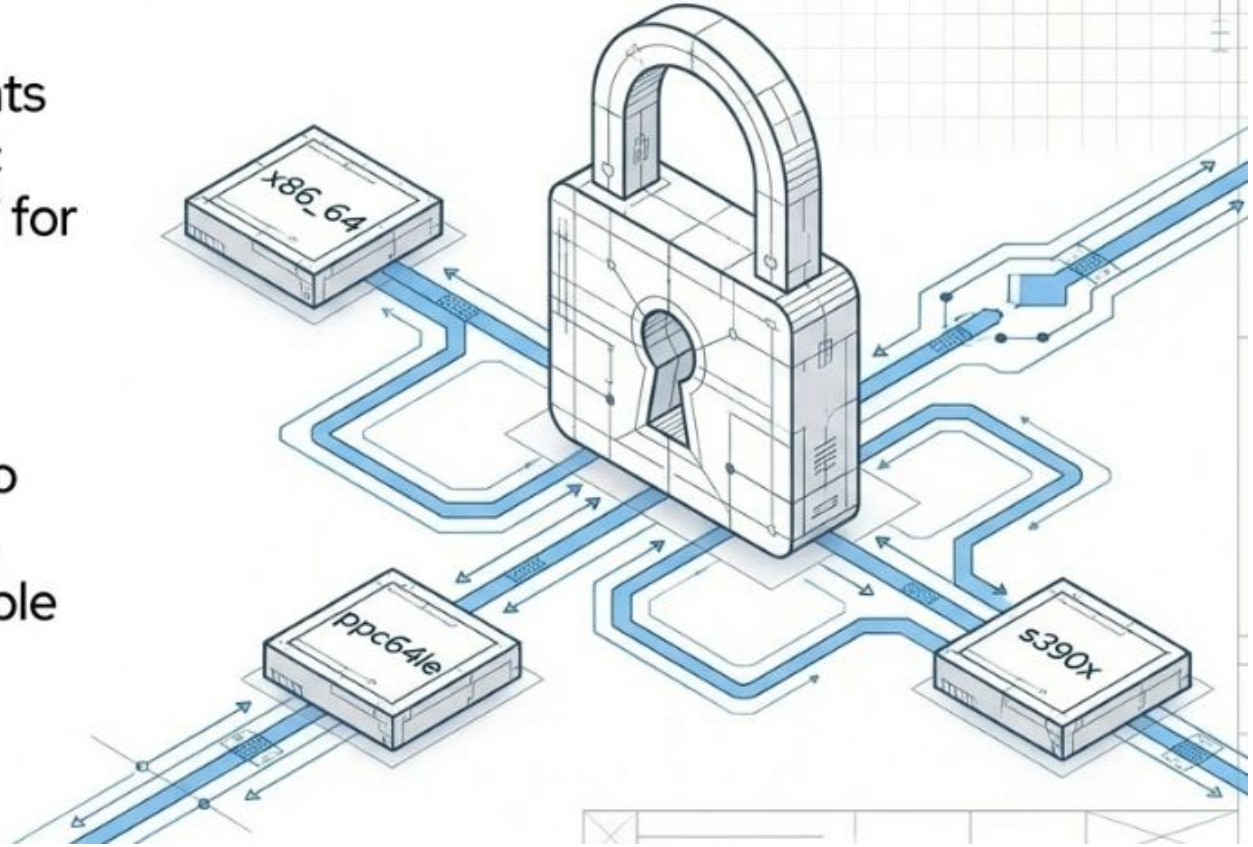
Hardware Layer
IBM Secure Execution
(Hardware-based isolation on Z/LinuxONE)

Cryptographic Integrity: FIPS 140-2 & 140-3

OpenShift core components utilize RHEL cryptographic libraries submitted to NIST for FIPS Validation.

Key Properties:

- Must be enabled prior to the first boot of the OS.
- Utilizes a FIPS-compatible Golang compiler.



Identity, Access, Secrets

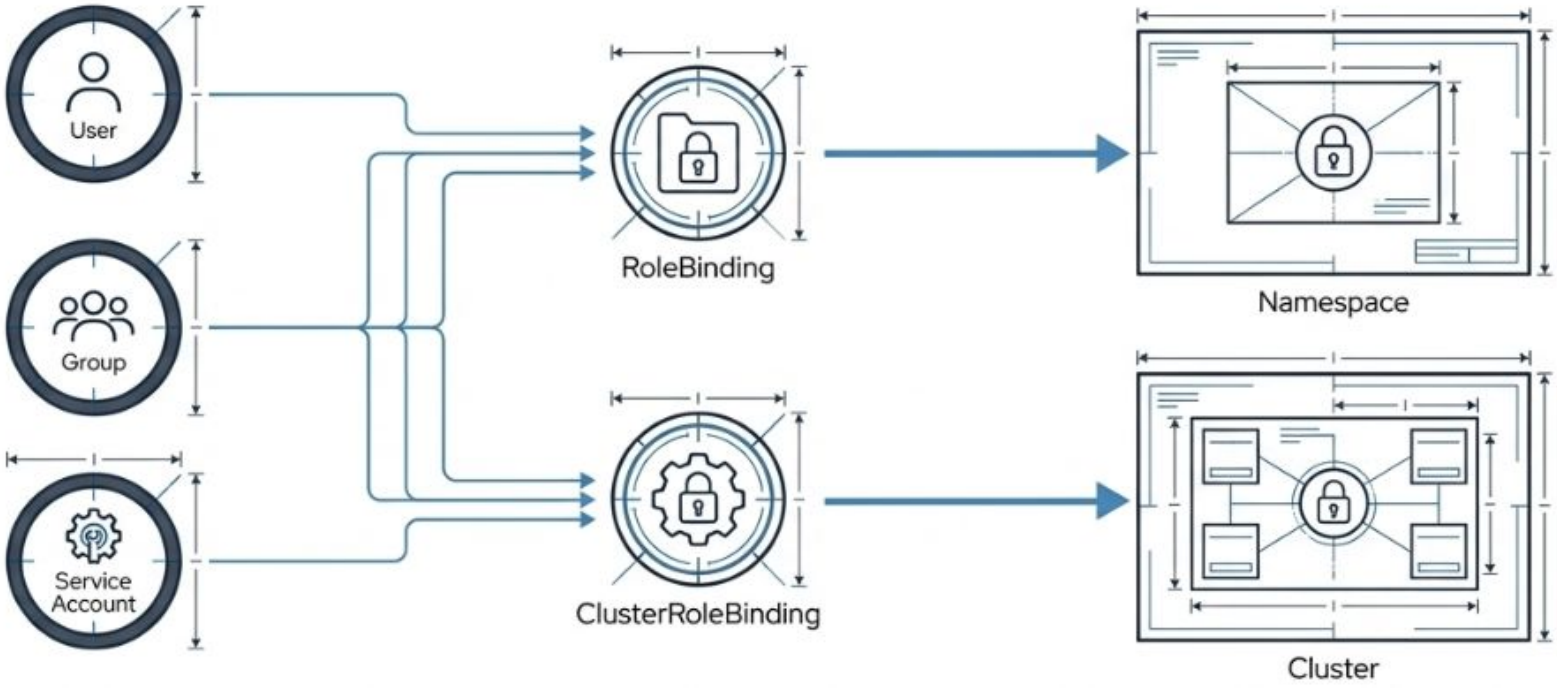
Identity and RBAC

- OAuth integration: LDAP, OIDC, SAML, and more
- Role-Based Access Control: cluster and namespace scope
- Service accounts and least-privilege defaults
- Audit logging of API and authentication events
- Separation of cluster admin vs. developer roles

The RBAC Constellation

Enforcing the Principle of Least Privilege.

- **RoleBinding**: Grants permissions within a specific namespace.
- **ClusterRoleBinding**: Grants permissions across all cluster resources.



Red Hat

Secrets and Certificates

- Kubernetes Secrets integrated with platform storage
- Certificate management for API, ingress, and internal components
- External secret operators (e.g. Vault) supported patterns
- etcd encryption at rest for API data (configuration-dependent)
- Image pull secrets and registry integration

Compliance and Hardening

Update **confidential** designator here

Compliance Operator

- Scans nodes and cluster against compliance profiles (e.g. CIS, FedRAMP-oriented)
- Reports remediation guidance and compliance status
- Integrates with organizational policy-as-code goals
- Supports scheduled scans and result retention
- Complements host-level hardening (e.g. through tuned profiles)

Red Hat

FIPS and Cryptography

- FIPS mode uses validated cryptographic modules on supported platforms
- Required for many government and financial workloads
- Install-time and platform constraints apply
- Validates algorithms and libraries per policy
- Coordinate with Red Hat documentation for version-specific enablement

FIPS

Network and Workloads

Update **confidential** designator here

Network Security

- NetworkPolicy for default-deny and allow-list patterns
- Egress controls and DNS-based policies (where supported)
- Ingress and Routes with TLS termination options
- Service mesh options for mTLS between services (optional add-ons)
- Multus and additional interfaces with careful policy design

Red Hat

Update **confidential** designator here

Workload Isolation

- Security Context Constraints limit pod capabilities
  - (root, volumes, caps)
- Pod Security Standards alignment in supported versions
- Namespaces as security and multi-tenant boundaries
- Optional: Kata Containers or similar for stronger isolation
- Resource quotas and limit ranges reduce noisy-neighbor risk

POD SECURITY

Red Hat

Supply Chain and Updates

Images and Updates

- Trusted Red Hat container images and signed payloads where applicable
- Cluster lifecycle: tested upgrade paths for CVE response
- Image scanning integration (partners and OpenShift pipelines)
- Software supply chain practices: SBOM, provenance (ecosystem evolving)
- Vulnerability monitoring via RHSA and OpenShift security bulletins

Certifications

Security Certifications (Examples)

Subject to offering and region

- Common Criteria / EAL-oriented evaluations for components (product/version specific)
- FedRAMP and U.S. government authorization paths for managed offerings
- SOC 2 Type II and ISO 27001 for cloud services (e.g. ROSA) – see Red Hat trust center
- PCI DSS responsibility model for workloads handling card data
- HIPAA BAA and regional data residency where offered by cloud providers

How to Use Certification Information

- Request the latest compliance documentation from Red Hat or your cloud provider
- Map shared responsibility: platform vs. customer configuration
- Run Compliance Operator scans against required profiles
- Include OpenShift version and deployment topology in audits
- Re-validate after major upgrades or architecture changes

Update **confidential** designator here

Summary

- OpenShift layers host, API, RBAC, network, and workload controls
- Compliance Operator, FIPS, and audit support regulated use cases
- Certifications apply to specific products and deployment models—verify current scope
- Security is shared: platform + your policies, scanning, and operations
- Always refer to docs.redhat.com and Red Hat compliance resources

Red Hat

Secure by Default. Certified by Design.

Red Hat OpenShift Container Platform

NotebookLM

linkedin.com/company/red-hat

youtube.com/user/RedHatVideos

facebook.com/redhatinc

twitter.com/RedHat

Red Hat